



il Chief Technology, Innovation & Digital Officer

Utilizzo corretto e sicuro delle Risorse Digitali

Tipologia documento:

Policy

ID: n° 65_v.01

Ambito di applicazione:

Gruppo

Processo:

Technology, Innovation
& Digital / Gestione
dispositivi e utenze

Data: 26/03/2024



INDICE

SUMMARY	4
GOVERNANCE DELLE RISORSE DIGITALI.....	6
Gestione delle utenze e meccanismi di autenticazione	6
Gestione delle dotazioni informatiche.....	7
Gestione dei servizi di comunicazione	9
Gestione della rete aziendale	12
Gestione degli Strumenti di archiviazione e collaboration.....	13
Gestione delle applicazioni software.....	14
DISPOSIZIONI PER IL PERSONALE	16
Disposizioni per l'utilizzo dei meccanismi di autenticazione.....	16
Disposizioni per l'utilizzo delle dotazioni informatiche	17
Disposizioni per l'utilizzo dei servizi di comunicazione aziendali	20
Disposizioni per l'utilizzo della rete aziendale, della consultazione delle risorse online (navigazione) e dei social network.....	22
Disposizioni per l'utilizzo delle applicazioni aziendali e dei servizi di archiviazione e collaboration.....	23
CONTROLLI SULLE RISORSE DIGITALI	25
Ciclo dei controlli.....	26
Monitoraggio e controllo delle attività degli Amministratori di Sistema.....	28
COMPORTAMENTI DIFFORMI ED INIZIATIVE CONSEGUENTI.....	29
ADEMPIMENTI NORMATIVI.....	30

DISCLAIMER

I principi e le regole di comportamento definiti nel presente documento costituiscono presidi di controllo anche ai fini anticorruzione e di prevenzione dei rischi di compliance e dei rischi-reato ex D. Lgs. 231/2001 dando attuazione a quanto previsto dal Modello di Organizzazione, Gestione e Controllo adottato dalle Società ai sensi del d.lgs. 231/2001 (Modello 231), dal Codice Etico del Gruppo FS Italiane, dalla Policy Anti-Corruption del Gruppo FS Italiane e dal Modello di Gestione Anti-Corruption¹, dal Framework di Data Protection e dal Framework di classificazione e protezione della riservatezza della informazione del Gruppo FS Italiane.

Si raccomanda ai Responsabili delle strutture coinvolte il costante monitoraggio del presente documento al fine di garantirne la corretta applicazione ed il costante adeguamento ai fini della sua efficacia. Chiunque venisse a conoscenza di eventuali violazioni o tentata elusione del presente documento è tenuto ad informare tempestivamente l'Organismo di Vigilanza e/o il Comitato Etico di Società, secondo le modalità previste dalla Procedura per la Gestione delle Segnalazioni e dal Modello 231

PRESIDI DI CONTROLLO

- ☒ D.lgs. 231/2001
- ☒ Anti-Corruption

¹ Ove adottato dalla Società. Il modello è stato pubblicato nella sua prima edizione con la denominazione “Anti-Bribery & Corruption management system” (DdG n. 247 P/AD del 23/02/2018 e corrispondenti documenti societari). Nel rispetto delle proprie peculiarità, Anas SpA ha adottato un proprio modello volontaristico di organizzazione e gestione per la prevenzione della corruzione e trasparenza.

OGGETTO

Il presente documento definisce principi e linee guida per una corretta e sicura gestione, accesso e utilizzo delle dotazioni informatiche e delle risorse digitali. Il documento identifica inoltre un sistema di verifiche e controlli volti ad evitare l'adozione di comportamenti in grado di danneggiare e/o mettere in pericolo la riservatezza, la sicurezza, l'integrità e la disponibilità delle informazioni gestite e di perseguire i seguenti obiettivi:

- individuare in maniera specifica gli *“strumenti utilizzati dal lavoratore per rendere la prestazione lavorativa”*, descrivendone le modalità d'uso e indicando le modalità di effettuazione dei controlli relativamente al loro utilizzo ai sensi delle correnti disposizioni di legge;
- proteggere la Società da atti illeciti e da abusi attuati mediante l'uso delle dotazioni informatiche e delle altre risorse digitali, prevenendo inoltre reati informatici e trattamento illecito di dati che possono comportare responsabilità amministrativa ai sensi del D.Lgs. n. 231/2001 e smi;
- incrementare il livello di sicurezza nel trattamento dei dati personali, applicando i principi della *data protection by design e by default*, il *rispetto del periodo di conservazione (Data Retention) stabilito dai rispettivi Data Manager per ogni singolo trattamento e garantendo, più in generale, il rispetto del Framework Data Protection di Gruppo*;
- adempiere agli obblighi dettati dalle *“Linee guida del Garante per posta elettronica ed Internet”* (di seguito “Provvedimento”) emanate dall'Autorità Garante per la protezione dei dati personali (di seguito “Garante”), e più in generale, dalla normativa in materia di protezione dati personali.

AMBITO DI APPLICAZIONE

- Ferrovie dello Stato Italiane SpA
- Società del Gruppo FS Italiane

ATTO DI DIREZIONE E COORDINAMENTO ☒

MODALITA' DI RECEPIMENTO DI POLO E DI ADOZIONE SOCIETARIA

Il presente documento è un atto di direzione e coordinamento a valenza di Gruppo².

Le Capogruppo di Settore e le altre Società soggette a direzione e coordinamento di FS SpA, adottano, nel rispetto delle proprie prerogative di autonomia ed indipendenza, il presente documento (atto di adozione).

Inoltre, le Capogruppo di Settore con il medesimo atto provvedono al recepimento del documento nell'ambito del rispettivo Polo (atto di recepimento di Polo).

Successivamente, le Società del Polo adottano il presente documento (atto di adozione).

In relazione alle peculiarità organizzative del singolo contesto, l'atto di adozione delle Società del Polo, nel caso in cui siano Sub-holding, può avere valenza anche sulle proprie controllate.

Le Società estere adottano i principi disciplinati in coerenza con l'ordinamento giuridico ove la Società ha la sede legale.

Ciascuna Società garantisce la corretta e costante applicazione di quanto definito e ne assicura la massima diffusione al proprio interno ed il relativo controllo attuativo anche presso le proprie controllate, nel rispetto degli obblighi di riservatezza e delle prerogative di autonomia ed indipendenza di ciascuna Società.

- ☒ Applicabilità diretta
- ☐ Applicabilità con caratterizzazione organizzativa
- ☐ Applicabilità con integrazione
- ☐ Applicabilità con definizione di processo

² Per Gruppo FS Italiane si intendono le Società, italiane o estere, controllate da FS S.p.A. ai sensi dell'art. 2359 comma 1, numeri 1) e 2) del Codice civile. Italcertifer S.p.A. non è soggetta a direzione e coordinamento, a ulteriore garanzia della sua indipendenza in relazione all'attività svolta. Gli atti di direzione e coordinamento emanati dalla Holding sono inviati ad Italcertifer quali descrizione degli indirizzi adottati nell'ambito del Gruppo FS, che potranno essere valutati dal management di Italcertifer nell'ambito della propria discrezionalità gestionale."

GOVERNANCE DELLE RISORSE DIGITALI

Al fine di consentire la corretta gestione delle risorse digitali, prevenire i rischi connessi alla perdita di riservatezza, integrità e disponibilità delle informazioni e incrementare il livello di sicurezza nel trattamento dei dati personali, nel presente capitolo si riportano le misure organizzative, procedurali e tecnologiche che le Società del Gruppo sono tenute ad applicare.

Gestione delle utenze e meccanismi di autenticazione

Al personale³ del Gruppo FS è attribuita una identità digitale che lo accompagna nel corso della sua attività professionale e che termina la sua efficacia con la cessazione del rapporto di lavoro o del rapporto di collaborazione. L'identità digitale protegge i sistemi informativi e le informazioni aziendali da accessi non autorizzati e, allo stesso tempo, attribuisce univocamente le azioni digitali alla corrispondente persona fisica⁴. Nel corso del rapporto di lavoro, inoltre, al personale possono essere attribuite specifiche utenze/autorizzazioni per l'accesso alle risorse digitali aziendali.

Le Società del Gruppo assicurano la gestione corretta e sicura delle utenze tramite la definizione dei seguenti processi:

- **Autorizzazione all'uso dei servizi:** definizione delle modalità con cui viene assegnata l'identità digitale ai dipendenti e delle modalità di creazione/modifica/cancellazione delle utenze per gli applicativi, prevedendo un *workflow* autorizzativo che coinvolga, come minimo i referenti di processo su cui insistono i servizi applicativi e i relativi Responsabili Gestione Autorizzazioni (RGA) appositamente nominati; è inoltre necessario in questa fase definire l'attribuzione dei con di visibilità, anche nel rispetto dei principi di *Segregation of Duties* e del *need to know/need to use* (accesso alle informazioni strettamente necessarie⁵ alle necessità operative). Per il personale esterno al Gruppo, le utenze devono essere autorizzate dai referenti di processo su cui insistono i servizi applicativi coerentemente con le modalità di gestione degli accessi in essere, nei casi strettamente necessari, su specifica e motivata richiesta del Gestore del contratto, limitatamente alla durata di tali rapporti e sulla base di comprovate necessità aziendali⁶.

³ Per "personale" si intende nel presente documento in una accezione ampia i dirigenti, i dipendenti, i collaboratori esterni che, in virtù di un rapporto di lavoro, parasubordinato o in qualsiasi forma costituito, o di un rapporto di fornitura (ad esempio, nel caso dei consulenti), utilizzano le dotazioni informatiche e/o le risorse digitali aziendali, ovvero accedono ai sistemi informatici di Gruppo. Per il "personale" esterno che opera, invece, in virtù di un rapporto di fornitura, l'accesso ai servizi aziendali è consentito tramite dispositivi di proprietà dell'Azienda fornitrice, configurati sulla base delle prescrizioni di sicurezza, da utilizzarsi in accordo alle regole e i principi riportati nella presente policy.

⁴ A titolo esemplificativo, il dipendente potrà richiedere un giorno di ferie e quest'azione sarà riconducibile univocamente al medesimo.

⁵ Anche in considerazione di quanto disposto dalla normativa interna di riferimento (cfr. Modello di Governance "Security").

⁶ Il gestore del contratto deve richiedere alle strutture competenti per i sistemi informativi ed informare i referenti di processo su cui insistono i servizi applicativi della rimozione delle utenze dei collaboratori esterni non appena cessata la necessità che ne ha determinato l'abilitazione o nei casi di altra natura che determinino la sospensione delle utenze. Il gestore del contratto, inoltre, deve verificare con cadenza semestrale le utenze concesse ai collaboratori esterni, e comunicare alle strutture competenti per i sistemi informativi la decisione di confermarle, variarle o cancellarle. Il gestore del contratto, infine, se richiesto dalle competenti strutture aziendali, deve fornire evidenza delle ultime due verifiche semestrali effettuate.

- **Autenticazione:** individuazione dei meccanismi di autenticazione proporzionati alla criticità delle informazioni aziendali accedute e alla delicatezza delle operazioni effettuate, prevedendo diversi livelli di verifica dell'identità digitale/utenza (dalla coppia nome utente-*password* alla *multi-factor authentication*)⁷.
- **Analisi e mantenimento:** definizione delle modalità sicure per gli interventi di manutenzione, di data retention dei *log*, di reimpostazione delle credenziali di accesso (ad es. se il dipendente ha dimenticato la *password* o il dispositivo di autenticazione), di sospensione e di blocco d'emergenza o cancellazione dei dati archiviati sui dispositivi, secondo i principi di *Security by Design* (anche da remoto), ad es. in caso di furti, smarrimenti o compromissione delle risorse digitali assegnate.

Per gli accessi privilegiati (amministratori di sistema o super-user che possono modificare/attribuire privilegi), sono previste misure procedurali e informatiche tali da garantire i diritti strettamente necessari allo svolgimento della mansione, il monitoraggio delle operazioni svolte (logging), il divieto di account amministrativi impersonali, etc.

L'accesso alle risorse digitali è consentito al solo utente assegnatario mediante le proprie credenziali di autenticazione. Un'eccezione a questa regola ricorre solo nel caso in cui si verifichi la prolungata assenza dell'utente o l'impossibilità manifesta da parte dell'utente di effettuare l'accesso alle risorse digitali e, contestualmente, tale accesso risulti indispensabile e indifferibile per ragioni di sicurezza delle informazioni, ivi inclusa la continuità operativa di business. In tali casi, deve essere previsto un iter procedurale specifico che includa (i) l'informativa all'utente assegnatario (ii) il coinvolgimento, oltre del Responsabile gerarchico, del Responsabile Gestione Autorizzazioni e della [funzione Data Protection](#).

Gestione delle dotazioni informatiche

Il Gruppo FS mette a disposizione del personale, in funzione della mansione svolta, dotazioni informatiche tra quelle riportate di seguito:

- Personal Computer: PC desktop, PC laptop
- Dispositivi mobili: tablet, smartphone
- Dispositivi di telefonia fissa
- Apparati integrativi della postazione di lavoro (stampanti, scanner, router wi-fi mobile etc.)
- Apparati per firma digitale (FEA, Firma Digitale, etc.)

Tali dispositivi possono essere utilizzati in modalità stand-alone (in locale) o per l'accesso alle risorse

⁷ I meccanismi di autenticazione evolvono nel tempo in funzione della tecnologia. I principali meccanismi di autenticazione messi a disposizione del Gruppo sono: Coppia nome utente-*password* / Dispositivi di autenticazione forte (One Time Password, token, smart card, certificati digitali, etc.). Il meccanismo di autenticazione al momento più diffuso nel Gruppo è costituito dalla coppia nome utente-*password*, utilizzato per l'accesso alla postazione di lavoro e, tramite meccanismi automatici di autenticazione, a diverse applicazioni aziendali (c.d. Single Sign-On). Pur non costituendo un meccanismo di autenticazione alle applicazioni, tra gli strumenti abilitanti dell'identità digitale sono inclusi anche i meccanismi di firma (FEA, Firma Digitale, meccanismi di espressione della volontà tra i quali, ad esempio, l'apposizione tracciata di flag di accettazione/presa visione etc.).

digitali e alle informazioni aziendali. Non è ammesso utilizzo promiscuo di dispositivi privati per finalità professionali (*bring your own device* – BYOD); le funzioni richiedenti delle Società riportano la richiesta di eventuali specifiche e residuali eccezioni, opportunamente motivate, alle strutture competenti per i sistemi informativi di FS Technology, in coordinamento con la [funzione Cyber di FS SpA](#).

Le Società del Gruppo assicurano la gestione corretta e sicura delle dotazioni informatiche tramite la definizione dei seguenti processi:

- **Assegnazione e revoca e dismissione dei dispositivi:** predisposizione e continuo aggiornamento di un registro contenente le principali informazioni relative ai dispositivi assegnati (nominativo, data di consegna, marca, modello, etc.) e definizione delle modalità operative per l'assegnazione, la revoca, la restituzione, la gestione dell'obsolescenza e la dismissione sicura e certificata dei dispositivi;
- **Installazione e configurazione dei dispositivi di gestione:** definizione delle modalità di configurazione in accordo con i principi di *cyber security* che prevedano procedure per la configurazione iniziale e sicura, prevedendo misure di sicurezza adeguate al rischio, tra le quali almeno le seguenti: (i) *End-Point encryption*, (ii) *Antivirus/Antimalware/Firewall/ Host Intrusion Prevention System (HIPS)*; (iii) *Mobile Application Management/ Mobile Device Management*, (iv) meccanismi di autenticazione per accesso ai dispositivi, quali ad esempio *smart card* per l'utilizzo delle stampanti condivise o l'applicazione di politiche specifiche per la scelta del PIN. In particolare, gli apparati dovranno essere configurati con utenza aziendale, prevedendo, in coerenza con le *policy* aziendali, la disponibilità di aree specifiche ad uso "privato" del dipendente ove inserire e gestire in autonomia i propri dati personali. Per gli apparati di telefonia mobile e fissa devono essere previste le seguenti profilazioni⁸:
 - Dispositivi *full-managed*: il dispositivo è configurato in modo tale da limitarne l'utilizzo da parte dell'utente, attraverso un controllo da remoto da una console di gestione su base *cloud*;
 - Dispositivi ibridi: sul dispositivo è permessa la configurazione di determinate applicazioni ad uso personale che non abbiano impatto sui dati aziendali e nel rispetto delle *policy* aziendali.
- **Gestione ordinaria:** definizione delle modalità di (i) installazione e aggiornamento delle applicazioni, manutenzione e back-up, (ii) sospensione/blocco d'emergenza (anche da remoto), ad esempio in caso di furti, smarrimenti o compromissione, (iii) gestione dell'obsolescenza e dismissione sicura⁹ delle dotazioni informatiche (iv) gestione delle attività conseguenti a furti/smarrimenti/deterioramento/distruzione.

⁸ Per quanto riguarda le SIM, la profilazione prevista è quella aperta, senza particolari restrizioni sulle utenze telefoniche contattabili e i dispositivi associabili. Eccezioni potrebbero essere presenti in seno a determinate SdG.

⁹ Le modalità di dismissione sicure sono tali da rendere impossibile il recupero delle informazioni ivi contenute. In caso di dismissione, reimpiego o riciclaggio di supporti magnetici od ottici contenenti dati personali o di rifiuti di apparecchiature elettriche ed elettroniche le strutture competenti per i sistemi informativi garantiscono che venga realizzata l'effettiva cancellazione dei dati in essi contenuti o la loro non intelligibilità anche in collaborazione con gli utenti delle apparecchiature stesse; tale misura è volta ad impedire a soggetti non autorizzati, che abbiano a vario titolo la disponibilità materiale dei supporti, di venire in possesso dei dati in essi contenuti non avendone diritto.

Gestione dei servizi di comunicazione

Per agevolare la prestazione lavorativa e soddisfare le esigenze di comunicazione nell'ambito dello svolgimento delle proprie mansioni, le Società del Gruppo mettono a disposizione del personale una casella nominale di **posta elettronica** e un **digital workspace** (chat, servizi di audio-video conferenza e social aziendali); limitatamente ad un ristretto gruppo di utenti, possono essere resi disponibili una casella nominale di **posta elettronica certificata (PEC)** e il **servizio di protocollazione**.

Le Società del Gruppo assicurano la gestione corretta e sicura dei servizi di comunicazione tramite la definizione dei processi per la richiesta, attivazione e utilizzo dei suddetti servizi., ferme restando le disposizioni di seguito riportate.

Per quanto attiene ai servizi di posta elettronica le Società del Gruppo formalizzano in apposite procedure: (i) le modalità di autorizzazione per i dipendenti e, in caso di necessità, del personale esterno (ii) i principi di configurazione (iii) le tempistiche e le modalità di conservazione dei messaggi e dei *log* in accordo a quanto disposto dalla normativa in materia di protezione dei dati personali (iv) le regole di archiviazione in ottemperanza agli obblighi definiti dal *Framework di Data Protection* (v) le modalità di gestione/diritti di accesso alle caselle di struttura/condivise; ferme restando le seguenti disposizioni:

- **Autorizzazione all'uso dei servizi:** in generale, il servizio di posta elettronica è concesso al personale contestualmente alla creazione dell'identità digitale aziendale e limitatamente alla durata del rapporto di lavoro. La compilazione dell'anagrafica utente è a carico della funzione Risorse Umane societaria, che avvia il processo di creazione dell'identità digitale a cura di FS Technology. Al personale esterno al Gruppo se strettamente necessario, può essere assegnata una casella di posta elettronica nominale o di Gruppo (con accesso tramite credenziali nominative) su richiesta del Gestore del contratto. Tale assegnazione è da intendersi per la durata, nei termini e per le finalità di esecuzione del rapporto di lavoro o del contratto di fornitura.
- **Configurazione:** il servizio di posta elettronica è configurato avendo cura di stabilire: (i) il numero massimo di indirizzi dei destinatari, (ii) le dimensioni massime per ciascun messaggio, (iii) lo spazio su *server* per ciascuna utenza o le dimensioni della casella di posta per la posta in *cloud*, (iv) i tempi di conservazione; (v) le regole di *back-up* delle caselle di posta.
- **Tempi di conservazione/Data retention:** le modalità operative relative all'applicazione dei criteri di data retention delle caselle di posta elettronica e dei relativi *backup* sono definite e condotte in coerenza con quanto definito dai rispettivi *Data Manager* dei relativi trattamenti ed in materia dalle determinazioni normative interne. In particolare, per la casella di posta elettronica del personale, i messaggi non possono risiedere sui *server* al fine di garantire contestualmente l'esigenza di continuità operativa e il rispetto dei tempi di conservazione richiesti dal Regolamento UE 2016/679. Per le caselle di struttura, di ruolo, dedicate a specifici processi operativi, trattandosi di comunicazioni aziendali rilevanti per la continuità operativa della struttura di appartenenza, i tempi di residenza su *server* possono essere preventivamente definiti dal Responsabile in funzione delle esigenze di processo. Per quanto attiene i *log* relativi ai *server* di posta ed eventuali sistemi di sicurezza (*anti-spam*) è previsto un tempo di conservazione non superiore a 12 mesi. Per la Posta Elettronica Certificata (PEC) i tempi di conservazione possono essere estesi fino ai 10 anni, secondo la

normativa vigente. FS Technology si impegna ad assicurare il rispetto dei tempi di conservazione. Per assicurare la continuità operativa, rispettando la normativa in materia di Data Protection, per la condivisione e conservazione di documenti contenenti informazioni e dati riguardanti l'attività lavorativa deve essere privilegiato l'impiego degli strumenti aziendali di *collaboration* (ad esempio *SharePoint*, *OneDrive* e *Teams*) in luogo della posta elettronica assicurando gli opportuni criteri autorizzativi e di minimizzazione secondo il principio di "need to know".

- **Regole di archiviazione:** è vietata all'utente la possibilità di archiviare la posta elettronica in locale o su ambienti messi a disposizione dall'azienda al di fuori dei periodi di data retention previsti. Per le caselle di struttura, di segreteria, e in caso di comunicazioni aziendali rilevanti per la continuità operativa della struttura di appartenenza, è richiesta l'archiviazione su ambienti messi a disposizione dell'azienda (ambienti di sharing). In tal caso i tempi di conservazione sono quelli previsti per i singoli processi operativi in capo alla struttura titolare della casella di posta. In entrambi i casi, per e-mail o allegati contenenti dati personali si ricorda la necessità di rispettare i tempi di conservazione stabiliti secondo le regole del *Framework di Data Protection*, provvedendo alla cancellazione/anonimizzazione dei messaggi non più necessari.
- **Utenti cessati:** in caso di cessazione del rapporto di lavoro (anche in caso di spostamenti di personale infragruppo), la casella di posta elettronica associata al dipendente è immediatamente disabilitata. Deve essere consentita l'implementazione di un messaggio automatico di risposta che espliciti al mittente i nuovi contatti aziendali delle strutture e funzioni cui rivolgersi individuati per la continuità operativa, mentre non è consentito l'inoltro automatico delle comunicazioni dalle caselle di posta disabilitate verso altri contatti.
- **Caselle di posta elettronica personali:** è una casella di posta elettronica assegnata a un singolo utente, il cui accesso avviene esclusivamente tramite credenziali aziendali personali. La casella di posta personale è destinata a soddisfare le esigenze professionali individuali dell'utente e non è condivisa con altri utenti, a differenza delle caselle di struttura, di ruolo o delle caselle condivise. Le caselle di posta elettronica personale, verranno cancellate a 90 giorni dalla cessazione del rapporto di lavoro. Al fine di assicurare la continuità operativa e preservare le informazioni non personali gestite dall'utente tramite posta elettronica, si raccomanda di favorire l'uso delle caselle di posta elettronica di struttura, di ruolo, condivise.
- **Caselle di struttura:** sulla base di necessità operative e/o organizzative possono essere predisposte caselle di struttura di posta elettronica in uso a più utenti in un ambito specifico (ad esempio, segreteria@XXX.it). L'accesso a tali caselle deve avvenire tramite il meccanismo delle deleghe, così che ciascun utente autorizzato avrà modo di accedere alla casella condivisa utilizzando le proprie credenziali aziendali nominative. La responsabilità delle autorizzazioni sulla casella rimane univocamente all'owner della casella di struttura.
- **Caselle di ruolo:** sulla base di necessità operative e/o organizzative possono essere predisposte caselle di ruolo di posta elettronica in uso ad un unico utente per volta che corrisponda ad un ruolo organizzativo (ad esempio, AmministratoreDelegato@XXX.it). L'uso di tali caselle è esclusivo del titolare pro-tempore del ruolo a cui la casella è attribuita, e deve essere gestita con le medesime modalità previste per le caselle ad uso personale, ivi compresa la gestione della delega. A differenza di queste ultime, trattandosi di caselle di servizio, queste devono essere utilizzate ai soli fini di

comunicazioni istituzionali connesse con il ruolo ricoperto allo scopo di garantire la continuità operativa nei processi di avvicendamento. Le caselle di ruolo, all'avvicinarsi del responsabile del ruolo aziendale (ad esempio al cambio di un Amministratore Delegato), sono riassegnate (cambio credenziali di accesso) al nuovo titolare del ruolo, senza cancellazione dei contenuti precedenti.

- **Meccanismi di delega:** i meccanismi di delega per l'accesso a caselle nominali di posta elettronica devono essere disincentivati, ridotti ai casi strettamente necessari e, nel caso, devono essere sempre preventivamente formalizzati. In alcuni casi è permessa l'autorizzazione a mandare e-mail con la dicitura “*per conto di*”, di modo che un delegato possa mandare un'e-mail a nome di un altro mittente. Tale autorizzazione deve prevedere una specifica delega con delle istruzioni che delineino i limiti di utilizzo e responsabilizzino il delegante/delegato.
- **Liste di distribuzione e criteri di assegnazione dei diritti sulle relative caselle di posta elettronica:** è così definito un elenco di indirizzi *e-mail*, raggruppati fra loro, che consente l'invio e la ricezione massiva di messaggi a più persone. Ogni lista è identificata con un indirizzo di posta elettronica principale unico a cui è associato un *owner* unico identificabile, e può contenere altri indirizzi di posta elettronica secondari. La richiesta dei diritti di accesso alle caselle derivanti da liste di distribuzione deve essere inviata dall'*owner* della casella postale, il quale riceverà dalla struttura abilitante, con cadenza mensile, l'elenco degli utenti con le relative autorizzazioni. Non deve essere consentita l'abilitazione della funzionalità dell'invio come “*send as*”, per consentire l'identificazione certa del mittente che invia corrispondenza con delega. L'unica opzione attivabile potrà essere quella dell'invio “per conto di”; in questo modo il destinatario avrà contezza che la *e-mail* sia stata inviata effettivamente dal mittente o da un suo delegato. Saranno tuttavia ammesse deroghe in caso di caselle postali che comunicano con il pubblico o per motivate esigenze. Nel caso di liste di distribuzione che si configurano come Caselle di Posta di Persone Fisiche (es. *alias*) i relativi diritti di accesso devono essere il più possibile limitati nel tempo.

Con riferimento **al servizio di PEC**, le modalità di accesso e di utilizzo sono disciplinate dal *provider* del servizio. Le Società del Gruppo formalizzano i ruoli e i casi d'uso per i quali è concesso il servizio.

Con riferimento **al servizio di protocollazione**, le Società del Gruppo formalizzano i casi d'uso che prevedono l'obbligo di protocollazione solo ed esclusivamente ai sensi della normativa vigente (il protocollo non deve essere utilizzato in sostituzione di altri strumenti di comunicazione, come la posta elettronica o la PEC). Devono essere implementati, inoltre, controlli per verificare che lo strumento venga utilizzato secondo le regole definite e che non vi siano abusi nell'utilizzo. Il sistema di protocollazione non deve essere utilizzato come sistema di archiviazione documentale ed è in ogni caso soggetto agli obblighi stabiliti dal *Framework di Data Protection*, in particolare rispetto a misure di sicurezza e tempi di conservazione, volte a consentire l'esercizio dei diritti degli interessati.

Per i servizi di *chat*, audio-video-conferenza e social aziendali le Società del Gruppo identificano gli strumenti messi a disposizione dei dipendenti sul *digital workspace*. Formalizzano, inoltre, le modalità di utilizzo di tali strumenti (*netiquette*, regolamento di utilizzo) e attivano la formazione necessaria per il *change management*.

Gestione della rete aziendale

La rete aziendale è l'insieme delle tecnologie – apparati e programmi – mediante le quali si realizza la connettività tra sistemi e applicazioni IT del Gruppo, oltre che la fruizione delle risorse *online* (navigazione). La rete aziendale, nell'interesse dei servizi tramite essa erogati, è uno strumento di lavoro, nonché un bene aziendale e la continuativa disponibilità della stessa è fattore strategico per il corretto funzionamento dei processi aziendali. Le Società del Gruppo mettono a disposizione del personale l'accesso alla rete aziendale e la piena fruizione dei servizi aziendali e disponibili *online* tramite **Rete dati LAN** della sede aziendale e **Rete dati Wi-Fi** della sede aziendale, ove disponibile.

È inoltre possibile accedere da remoto alla rete aziendale, previa autorizzazione delle competenti strutture per i sistemi informativi e di Cyber Security Solutions & Operations di FST, mediante un servizio di *Virtual Private Network* (VPN) aziendale. In questo caso l'accesso potrà avvenire tramite **Rete dati di telefonia mobile cellulare** (SIM) o **Rete dati internet domestica** (Adsl o similari); non è ammesso il collegamento VPN aziendale tramite connessioni pubbliche non protette¹⁰ (*internet point, bar, etc.*).

È vietato l'utilizzo di qualsiasi connessione VPN diversa da quella indicata dalle competenti strutture e senza previa autorizzazione.

Le connessioni alla VPN aziendale per i fornitori e le terze parti possono essere attivate su richiesta del Gestore del contratto, nei casi strettamente necessari, su specifica richiesta alla struttura abilitante, limitatamente alla durata di tali rapporti e sulla base di comprovate necessità aziendali. Tutte le attivazioni di connessioni VPN per fornitori e terze parti devono essere opportunamente documentate, fornendo dettagli sulla ragione dell'attivazione, la durata prevista e le misure di sicurezza adottate durante il periodo di connessione.

Sono altresì disponibili ed accessibili dall'esterno, indipendentemente dal fatto che il dispositivo utilizzato per l'accesso sia aziendale o privato, una serie di servizi esposti sul *web* quali a titolo esemplificativo portale intranet aziendale, la Posta Elettronica, etc.

Le Società del Gruppo assicurano la gestione corretta e sicura della rete aziendale tramite la definizione dei processi di autorizzazione e regole di utilizzo della rete, ferme restando le disposizioni di seguito riportate:

- **Autorizzazione all'uso della rete:** in generale, l'autorizzazione all'uso delle reti disponibili è concessa al personale contestualmente alla creazione dell'identità digitale aziendale e limitatamente alla durata del rapporto di lavoro. Per il personale esterno al Gruppo, i suddetti servizi possono essere attivati su richiesta del Gestore del contratto, nei casi strettamente necessari, su specifica richiesta alla struttura abilitante, limitatamente alla durata di tali rapporti e sulla base di comprovate necessità aziendali¹¹.

¹⁰ Per connessioni pubbliche protette si intendono le reti con accesso tramite credenziali nominative.

¹¹ Il Gestore del contratto deve richiedere alle strutture competenti per i sistemi informativi la rimozione dei diritti di accesso dei collaboratori esterni alla rete aziendale non appena cessata la necessità che ne ha determinato l'abilitazione. Il Gestore del contratto, inoltre, deve verificare con cadenza semestrale le abilitazioni di accesso alla rete aziendale concesse ai collaboratori esterni, e comunicare alle strutture competenti per i sistemi informativi la decisione di confermare, variarle o cancellarle. Il Gestore del contratto, infine, se richiesto dalle competenti strutture aziendali, deve fornire evidenza delle ultime due verifiche semestrali effettuate.

- **Regole per l'uso dei servizi:** per ridurre il rischio di usi impropri della navigazione *Internet* (consistenti in attività non correlate alla prestazione lavorativa quali la visione di siti non pertinenti, l'*upload* o il *download* di file, l'uso di servizi di rete con finalità ludiche o estranee all'attività) e per prevenire controlli successivi sul personale, tenendo conto delle peculiarità proprie di ciascuna organizzazione produttiva e dei diversi profili professionali, sono adottate le seguenti misure:
 - configurazione di sistemi o utilizzo di filtri che prevengano determinate operazioni – reputate incoerenti o che potrebbero mettere a repentaglio la sicurezza delle informazioni e del sistema informatico della Società, ovvero provocare alla stessa un danno con l'attività lavorativa – quali l'*upload* o l'accesso a determinati siti (inseriti in *black list*) e/o il *download* di *file* o *software*;
 - identificazione di categorie di siti considerati non correlati con la prestazione lavorativa, tra le quali rientrano ad esempio i servizi di *streaming* per la visione di serie TV e film, nonché quelli per l'ascolto di audio per finalità ricreative.

Gestione degli Strumenti di archiviazione e collaboration

Le Società del Gruppo mettono a disposizione del personale, servizi di archiviazione e di *collaboration* autorizzati:

- **Servizi di archiviazione e collaboration in cloud** e relativi meccanismi di condivisione (quali a titolo esemplificativo i servizi disponibili sul digital workspace di WE);
- **Servizi di archiviazione e collaboration on premises** gestiti dal Security Operation Center della struttura Cyber Security Solutions & Operations di FST.

Le Società del Gruppo assicurano la gestione corretta e sicura degli strumenti di archiviazione e collaboration tramite la definizione dei processi di autorizzazione e regole di utilizzo, ferme restando le disposizioni di seguito riportate.

- **Autorizzazione all'uso dei servizi di archiviazione e collaboration:** in generale, l'autorizzazione all'uso dei servizi di archiviazione e *collaboration* disponibili sul *digital workspace* di WE è concessa al personale contestualmente alla creazione dell'identità digitale aziendale e limitatamente alla durata del rapporto di lavoro. Al personale esterno, i suddetti servizi possono essere attivati su richiesta del Gestore del contratto, nei casi strettamente necessari, su specifica richiesta, limitatamente alla durata di tali rapporti e sulla base di comprovate necessità aziendali¹². L'autorizzazione all'uso dei servizi di archiviazione e collaboration *on premises*, gestiti dal centro operativo della Struttura Cyber Security Solutions & Operations di FST, è concessa solo in caso

¹² Il Gestore del contratto deve richiedere alle strutture competenti per i sistemi informativi la rimozione dei diritti di accesso dei collaboratori esterni agli strumenti di archiviazione e collaboration non appena cessata la necessità che ne ha determinato l'abilitazione. Il Gestore del contratto, inoltre, deve verificare con cadenza semestrale le abilitazioni di accesso agli strumenti di archiviazione e collaboration concesse ai collaboratori esterni, e comunicare alle strutture competenti per i sistemi informativi la decisione di confermare, variarle o cancellarle. Il Gestore del contratto, infine, se richiesto dalle competenti strutture aziendali, deve fornire evidenza delle ultime due verifiche semestrali effettuate.

di gestione di informazioni confidenziali o strettamente confidenziali¹³ e in caso di trattamento di categorie particolari di dati personali.¹⁴

- **Regole per l'uso dei servizi:** devono essere adottate e definite politiche di *change management* e regole per l'utilizzo dei servizi di archiviazione e *collaboration* (es. rendendo disponibili su WE appositi manuali operativi) che incentivino:
 - la migrazione delle c.d. “cartelle condivise” presenti su *server on premises* verso i servizi “autorizzati” dall'azienda che dispongono delle caratteristiche di sicurezza necessarie a garantire la disponibilità dei file anche in caso di furto, smarrimento, distruzione, guasto o malfunzionamento del PC, e l'integrità dei file in caso di modifiche deliberate o accidentali;
 - l'utilizzo privilegiato degli strumenti aziendali di *collaboration* in luogo della posta elettronica;
 - il divieto di utilizzo di eventuali ulteriori strumenti di *sharing*, quali le piattaforme dedicate alla registrazione, archiviazione, trasmissione di informazioni non incluse negli strumenti descritti precedentemente (ad es. WeTransfer, Google Drive, server non autorizzati etc.). In casi strettamente necessari è possibile rivolgersi alle strutture competenti per i servizi informativi e a Cyber Security Solutions & Operations di FST per l'analisi dei requisiti di tali strumenti alternativi.

Gestione delle applicazioni software

Le applicazioni software sono i servizi IT a supporto dei processi di business e di staff, resi disponibili agli utenti per l'esecuzione delle mansioni loro assegnate.

Le Società del Gruppo assicurano la gestione corretta e sicura delle applicazioni software tramite la definizione dei processi di (i) catalogazione, (ii) autorizzazione, (iii) gestione e assegnazione dei ruoli applicativi, (iv) gestione misure di sicurezza e del trattamento dei dati, ferme restando le disposizioni di seguito riportate:

- **Catalogo delle applicazioni:** è necessario stilare un elenco degli applicativi software autorizzati all'interno della Società. Per tutte le applicazioni il catalogo deve indicare almeno:
 - il nome del sistema, la funzione/la descrizione;
 - il gestore dell'applicazione;
 - le informazioni di configurazione ed il *vendor*;
 - la presenza di informazioni confidenziali/strettamente confidenziali e/o di categorie particolari di dati personali; nonché gli esiti di eventuali *business impact analysis*;

¹³ secondo quanto previsto dal Modello di Governance “Security”.

¹⁴ ex art. 9 GDPR dati personali che rivelino l'origine razziale o etnica, le opinioni politiche, le convinzioni religiose o filosofiche, o l'appartenenza sindacale, dati genetici, dati biometrici dati relativi alla salute o alla vita sessuale o all'orientamento sessuale.

- tutte le informazioni necessarie alla prevenzione, rilevazione e contrasto degli incidenti di sicurezza per come definite dalla competente struttura per la *cyber security*;
- l'appartenenza alla lista delle risorse digitali rientranti negli obblighi di sicurezza nazionale cibernetica.
- **Autorizzazione all'uso dei servizi:** in generale, l'autorizzazione all'uso delle applicazioni software è concessa in funzione della mansione svolta e del ruolo gerarchico ricoperto. Al personale esterno, i suddetti servizi possono essere attivati su richiesta del Gestore del contratto¹⁵, nei casi strettamente necessari, su specifica richiesta, limitatamente alla durata di tali rapporti e sulla base di comprovate necessità aziendali.
- **Gestione e assegnazione dei ruoli applicativi:** per ciascuna applicazione *software* sono definiti:
 - modalità di associazione univoca dell'utenza all'identità digitale del dipendente/soggetto esterno, ad es. tramite il Codice Identificativo Dipendente (CID);
 - catalogo dei Ruoli Applicativi di sistema che deve contenere l'elenco dei singoli ruoli presenti nel sistema, raggruppati secondo logiche di processo e riportanti la descrizione delle attività che possono essere effettuate a sistema dall'utente associato, nonché la relativa regola di assegnazione anche nel rispetto del principio di *Segregation of Duties*;
 - regole di gestione del ciclo di vita dei ruoli e di assegnazione alle utenze (creazione/modifica/cancellazione delle utenze).
- **Misure di sicurezza:** tutte le applicazioni *software* autorizzate devono presentare livelli di sicurezza adeguati, con particolare riguardo a quanto definito nel *Framework di Data Protection* di Gruppo, nel *Modello di Governance "Security"* e nella *la libreria delle misure di sicurezza Cyber/Data Protection pubblicata sul portale WE*. Ulteriori e adeguate misure sono adottate per particolari realtà lavorative nelle quali debba essere rispettato l'eventuale segreto professionale cui siano tenute specifiche figure professionali.
- **Tracciatura e trattamento dati:** ove possibile, sulle applicazioni software devono essere implementati meccanismi automatici che garantiscano la *compliance* alla normativa in materia di *data protection*. In particolare:
 - informativa sulla tracciatura degli accessi e delle operazioni degli utenti del sistema nel rispetto della Data Retention del trattamento;
 - designazione delle "persone autorizzate al trattamento" (incaricati, amministratori di sistema) per i sistemi sui quali è previsto il trattamento di dati personali.

Tali disposizioni sono obbligatorie anche in caso di sviluppo di nuovi sistemi e andranno considerate in fase di progettazione.

¹⁵ Il Gestore del contratto deve richiedere alle strutture competenti per i sistemi informativi la rimozione dei diritti di accesso dei collaboratori esterni alle applicazioni aziendali non appena cessata la necessità che ne ha determinato l'abilitazione. Il Gestore del contratto, inoltre, deve verificare con cadenza semestrale le abilitazioni di accesso alle applicazioni aziendali concesse ai collaboratori esterni, e comunicare alle strutture competenti per i sistemi informativi la decisione di confermare, variarle o cancellarle. Il Gestore del contratto, infine, se richiesto dalle competenti strutture aziendali, deve fornire evidenza delle ultime due verifiche semestrali effettuate.

DISPOSIZIONI PER IL PERSONALE

Tutte le risorse digitali messe a disposizione del personale da parte delle Società del Gruppo sono strumenti di lavoro; pertanto, il loro utilizzo deve ispirarsi al rispetto dell'obbligo di fedeltà del lavoratore ed ai principi di diligenza, correttezza e buona fede. Nel presente capitolo si riportano le principali categorie di risorse digitali e, per ciascuna di esse, le principali modalità e regole di utilizzo.

Tali modalità e regole di utilizzo integrano le norme del Codice Etico di Gruppo, la normativa di riferimento, anche aziendale, in materia di protezione dei dati personali e le disposizioni aziendali vigenti in materia di data classification e rappresentano un presidio di prevenzione dei reati ex D-lgs. n. 231/2001 e s.m.i. e ai fini anticorruzione.

Si precisa che le disposizioni si applicano, per quanto possibile, anche alle risorse digitali esterne al Gruppo (per esempio, un sistema messo a disposizione da un fornitore o dalla Pubblica Amministrazione), laddove l'utente agisca nell'ambito del rapporto di lavoro in nome e per conto delle Società del Gruppo FS.

Disposizioni per l'utilizzo dei meccanismi di autenticazione

Uno dei requisiti fondamentali per la tutela del patrimonio informatico ed informativo del Gruppo FS è la riservatezza dei meccanismi di autenticazione associati all'identità digitale, ai dispositivi o alle applicazioni utilizzate. A tal fine sono operativi strumenti di rilevamento automatico di anomalie nell'utilizzo delle credenziali di accesso.

Pertanto, è necessario che il personale si attenga alle seguenti disposizioni:

- Non è consentito detenere e/o utilizzare abusivamente meccanismi (ad es. dispositivi OTP) o credenziali di accesso (ad es. *password*) diversi da quelli formalmente assegnati per lo svolgimento delle proprie attività. Tali risorse devono essere considerate strettamente personali e non condivisibili con persone all'interno o all'esterno della Società, in quanto essenziali per la sicurezza delle informazioni. Le *password* devono essere utilizzate e custodite con la massima riservatezza e diligenza e non è ammesso utilizzare la registrazione automatica della *password* nei sistemi di autenticazione.
- I meccanismi e le modalità di autenticazione devono conformarsi a quanto previsto dalla libreria delle misure di sicurezza Cybersecurity/Data Protection per PDL (fisse/laptop) e MOBILE (smartphone/tablet).
- Le *password* adottate per accedere alle risorse digitali e alle informazioni aziendali non devono essere utilizzate per autenticarsi su sistemi non aziendali.
- In caso di sospetto che le credenziali per l'autenticazione (*password*, OTP, altro) siano disponibili a terzi, è necessario cambiare immediatamente la *password* e segnalarlo, secondo le procedure aziendali in materia di violazione di sicurezza informatica e di *data breach*.
- I dispositivi di autenticazione forte (per es. *smart card*, *token*) devono essere custoditi attentamente, segnalando tempestivamente alle strutture competenti il loro furto/smarrimento. Inoltre, l'utente

ha l'obbligo di sporgere denuncia alle Forze dell'Ordine senza ingiustificato ritardo, e fornire, secondo le disposizioni societarie in materia, la copia dell'atto di denuncia.

- Se l'utente non dispone delle credenziali di accesso (ad es. dimentica la propria *password* o dimentica il dispositivo per la *multi-factor authentication*) deve personalmente eseguire la richiesta di sblocco/abilitazione nelle modalità previste dalle disposizioni aziendali.

Disposizioni per l'utilizzo delle dotazioni informatiche

Le dotazioni informatiche sono consegnate al personale correttamente configurate per il regolare uso nell'ambito lavorativo e i privilegi assegnati sulla base delle mansioni svolte. Su tali dotazioni sono operativi strumenti di rilevamento automatico di conformità dei dispositivi e di sicurezza della rete aziendale. Pertanto, è necessario che il personale si attenga alle seguenti disposizioni:

Disposizioni per l'utilizzo delle dotazioni

- L'utente non deve modificare nessuna configurazione hardware delle dotazioni assegnate.
- L'utente non deve modificare i privilegi a lui assegnati e non può essere assegnatario di privilegi di amministratore.
- L'utente non deve installare e/o eseguire sui dispositivi assegnati nessun *software* diversi da quelli preinstallati, anche nel caso in cui si tratti di *software* dotato di licenza, di *software* in prova ("*shareware*"), ovvero di *software* gratuito e liberamente scaricabile da Internet ("*freeware*"). Non è consentito utilizzare *software online* non autorizzati (es. per la conversione di file .pdf aziendali o per la generazione di slide e grafici). È vietata la rimozione arbitraria dei programmi di sicurezza (antivirus, *software* per la gestione del dispositivo da remoto, etc.). Eventuali eccezioni devono essere autorizzate preventivamente dal soggetto tecnico per i sistemi informativi, in coordinamento, ove necessario, con la struttura di Cyber Security Solutions & Operations di FST.
- Per gli utenti che, per comprovate esigenze di servizio, dispongono di SIM abilitate al traffico voce e dati in ambito non UE, stante l'elevato costo per l'Azienda derivante dall'utilizzo di tali servizi, l'utilizzo dell'apparato per ragioni non strettamente legate ad attività lavorative in ambito non UE è da limitare il più possibile e deve costituire una eccezione, nel rispetto dei principi di ragionevolezza e di buona fede (imprescindibili nella esecuzione del rapporto di lavoro) e, comunque, senza mettere a repentaglio la sicurezza delle informazioni e del sistema informatico della Società, ovvero provocando alla stessa un danno. Eventuali utilizzi eccedenti rispetto a quanto sopra indicato potranno essere soggetti a verifica puntuale da parte della Società.
- Ogni utente è responsabile dei dispositivi assegnatogli, ed è tenuto a custodirli diligentemente al fine di prevenirne il danneggiamento, il furto, o lo smarrimento. Il dispositivo non deve mai essere lasciato incustodito senza aver precedentemente provveduto a bloccare l'accesso al sistema e, in caso di dispositivo portatile, questo deve essere riposto in un luogo sicuro, a maggior ragione se portato all'esterno delle sedi aziendali.
- In caso di furto o smarrimento, l'utente assegnatario delle dotazioni informatiche ha l'obbligo d'informare tempestivamente il proprio diretto responsabile e notificare l'evento secondo le disposizioni societarie in materia per la gestione di potenziali Data Breach secondo il Framework

di Data Protection del Gruppo. Inoltre, l'utente ha l'obbligo di sporgere denuncia alle Forze dell'Ordine senza ingiustificato ritardo, e fornire, secondo le disposizioni societarie in materia, la copia dell'atto di denuncia (che deve necessariamente contenere anche la marca, il modello, e il numero identificativo del dispositivo).

- L'utente non deve permettere a soggetti non autorizzati di utilizzare il proprio dispositivo.
- La documentazione aziendale, o comunque rilevante per l'attività condotta dall'assegnatario di un dispositivo aziendale, deve essere mantenuta in cartelle sincronizzate con gli spazi cloud aziendali (OneDrive, Sharepoint, Teams) forniti e configurati al momento dell'assegnazione del dispositivo.
- In caso di cessazione del rapporto di lavoro, ovvero in caso di sostituzione o restituzione delle dotazioni informatiche, l'utente deve, con il supporto del soggetto tecnico per i sistemi informativi e in collaborazione con il proprio Responsabile, assicurare il trasferimento di tutta la documentazione rilevante per la continuità aziendale in maniera sicura e controllata. Ogni volta che un nuovo dispositivo viene consegnato ad un utente, questi deve contestualmente restituire, qualora in possesso, il vecchio dispositivo in dotazione privo di dati ed informazioni (procedendo prima alla procedura di reset).
- Le dotazioni informatiche e, in particolare, il personal computer non devono per nessun motivo essere utilizzate come server per erogare servizi IT. Eventuali esigenze di tipo informatico devono essere indirizzate verso la competente struttura per i sistemi informativi.
- Con particolare riferimento al software di sicurezza installato sulle dotazioni informatiche, ogni utente deve segnalare alle strutture competenti per i sistemi informativi ogni eventuale malfunzionamento del *software* di sicurezza installato sulle proprie dotazioni e, senza ingiustificato ritardo, tutti i casi in cui il *software* antivirus abbia rilevato una minaccia e non riesca ad eliminarla.
- Ogni utente deve tenere comportamenti volti a massimizzare l'efficacia delle misure di protezione adottate (ad esempio, accedere periodicamente alla rete aziendale al fine di tenere aggiornati il *software* antivirus e di sistema).
- È vietato installare, elaborare, duplicare, detenere, trasferire materiale soggetto a *copyright*, inclusi programmi, documenti, immagini, materiali audio e video al di fuori dei termini delle licenze.
- È vietato elaborare, duplicare, detenere, trasferire dati personali per cui non si sia stati incaricati dal data manager del trattamento degli stessi.
- È vietato installare, elaborare, conservare, trasferire materiale pornografico in genere, nonché programmi, documenti, immagini, materiali audio e video o informazioni di vario tipo che offendano il pubblico pudore o che siano diffamatori, osceni, indecenti o lesivi della dignità umana.
- Non è ammesso l'utilizzo di dispositivi removibili (Hard Disk esterni, chiavi o memorie esterne USB o SDD ecc.), se non autorizzati dalle funzioni competenti per la Cyber Security Solutions & Operations di FST e i sistemi informativi che, in funzione della richiesta, forniranno indicazioni rispetto alle misure di sicurezza da applicare al dispositivo o ai file.
- In caso di furto o smarrimento del dispositivo con archiviazione di memoria, l'utente assegnatario delle dotazioni informatiche ha l'obbligo d'informare tempestivamente il proprio diretto Responsabile e notificare l'evento secondo le disposizioni societarie in materia e del Framework di

Data Protection, in particolare della Procedura relativa Gestione delle Violazioni di Dati Personali (*Personal Data Breach*). Affinché possano essere avviate tutte le attività volte per la tutela della Società e del suo patrimonio informativo (ad esempio, blocco della SIM, blocco del telefono, cancellazione delle informazioni memorizzate sul telefono, etc.), l'utente ha l'obbligo di sporgere denuncia alle Forze dell'Ordine senza ingiustificato ritardo, e fornire, secondo le disposizioni societarie in materia, la copia dell'atto di denuncia (che deve necessariamente contenere anche la marca, il modello, il codice IMEI del dispositivo e il numero MSISDN dell'utenza a lui assegnata), eventualmente interfacciando la competente funzione di asset management per il reperimento di tali informazioni.

Disposizioni per l'utilizzo della telefonia fissa

Il sistema di telefonia fissa deve essere utilizzato per scopi lavorativi. È consentito utilizzare il sistema di telefonia fissa per scopi non immediatamente correlati alla prestazione lavorativa, purché ciò avvenga nel rispetto dei principi di ragionevolezza e di buona fede (imprescindibili nella esecuzione del rapporto di lavoro). Per maggiore chiarezza, l'utente può occasionalmente utilizzare il sistema di telefonia fissa per motivi personali, con modalità che non arrechino intralcio e/o rallentamento alla normale attività lavorativa propria o di terzi, nel rispetto delle disposizioni di legge, dell'etica aziendale e del buon costume, degli obblighi di riservatezza e delle regole stabilite da specifiche normative interne. Le chiamate effettuate per motivi personali non devono essere indirizzate verso numerazioni a sovrapprezzo (ad esempio, quelle con prefisso 892, 894, 899, etc.).

Disposizioni per l'utilizzo degli apparati integrativi della postazione di lavoro e firma digitale

- Ogni utente deve custodire con diligenza gli apparati integrativi al fine di prevenirne il danneggiamento, il furto, o lo smarrimento. Con particolare riferimento agli apparati per la firma digitale, è necessario conservare i *token* con la massima cura e diligenza segnalando immediatamente eventuali furti o smarrimenti al proprio diretto Responsabile e notificando l'evento secondo le disposizioni societarie vigenti in materia. Inoltre, l'utente ha l'obbligo di sporgere denuncia alle Forze dell'Ordine senza ingiustificato ritardo, e fornire, secondo le disposizioni societarie in materia, la copia dell'atto di denuncia.
- I file contenenti informazioni e dati che riguardano l'attività lavorativa non devono essere archiviati su supporti di memoria rimovibili (ad esempio, chiavette USB o *hard disk* esterni) o spazi di archiviazione non autorizzati (ad esempio, Google Drive, Dropbox, etc.). A tal proposito, la Società si riserva la facoltà di inibire il trasferimento di file verso supporti di memoria rimovibili o spazi di archiviazione non autorizzati.
- Nel caso di stampe, evitare sprechi avendo cura di stampare esclusivamente ciò che è indispensabile e che non è possibile visualizzare ed utilizzare in modo digitale.
- Nell'uso delle fotocopiatrici multifunzione di edificio con accesso controllato tramite badge aziendale, l'utente deve aver cura di effettuare il logout a fine lavori e considerare che il loro utilizzo prevede la contabilizzazione dei consumi e della tipologia di attività svolte.

Disposizioni per l'utilizzo dei servizi di comunicazione aziendali

Tutti gli strumenti e i servizi per lo scambio di informazioni, per audio-video-conferenza e messaggistica messi a disposizione dal Gruppo FS, sono funzionali alle attività lavorative e sono protetti al fine di garantire l'integrità, la disponibilità e la riservatezza delle informazioni scambiate. A tal fine sono operativi strumenti di rilevamento automatico della sicurezza dei servizi aziendali di comunicazione.

Nell'uso dei servizi di comunicazione aziendali, oltre a quanto riportato nei paragrafi precedenti, è necessario che il personale si attenga alle seguenti disposizioni.

- Ogni utente è responsabile del corretto utilizzo delle caselle di posta elettronica che gli vengono assegnate, così come del contenuto dei messaggi che trasmette. Per quanto concerne le caselle di posta di struttura in uso a più utenti, la responsabilità è condivisa tra gli utenti autorizzati all'utilizzo di ciascuna casella, ma deve essere comunque identificata la responsabilità univoca di un referente per la gestione delle autorizzazioni di accesso alla casella e degli altri obblighi legati alla gestione della casella stessa.
- In generale, l'utilizzo della posta elettronica aziendale deve aver luogo nel rispetto delle disposizioni di legge, dell'etica aziendale, degli obblighi di riservatezza e degli standard previsti dalle specifiche normative interne. In particolare:
 - L'utente deve inviare i messaggi/e-mail solo ai soggetti interessati, in coerenza con i ruoli e le responsabilità loro attribuiti.
 - È vietato leggere messaggi/e-mail destinati ad altri. Qualora l'utente fosse destinatario erroneo di un messaggio, quest'ultimo deve notificarlo al mittente, evitando l'inoltro del messaggio al destinatario, e provvedere alla cancellazione del messaggio.
 - È vietato inviare messaggi/e-mail mediante chat offensivi e/o osceni e, in ogni caso, in contrasto con il Codice Etico e con le disposizioni di Gruppo.
 - È vietato inviare materiale protetto da *copyright* senza le necessarie preventive autorizzazioni.
 - È vietato inviare/inoltrare (sia all'interno che all'esterno dell'Azienda) messaggi pubblicitari o promozionali, sia massivi (*spam*) che non, a meno che ciò non rientri nello svolgimento delle proprie mansioni.
 - È vietato inviare messaggi o allegati a contenuto contrario a norme di legge, all'ordine pubblico o al buon costume (materiale pornografico, messaggi dal contenuto scurrile, violento o, in qualsiasi modo, lesivo di persone, razze, sesso e religioni). A tal proposito, va chiarito che un utilizzo improprio della casella di posta elettronica aziendale potrebbe arrecare, anche indirettamente, danni alla Società (perdita di immagine e danno reputazionale, perdite economiche, sanzioni legali, etc.), è beninteso che sono a carico dell'utente le potenziali conseguenze, anche di natura legale, derivanti dall'invio di messaggi di posta elettronica da caselle assegnate e/o utilizzate all'utente stesso.

- Non rispondere a solleciti inviati attraverso messaggi/e-mail (ad es. *chain letters*) e non aprire allegati (ad es. con estensioni “.exe”, “.bat”) o attivare link o URL che rinviano a siti *web*, all’interno di messaggi sospetti o con contenuti pubblicitari, provenienti da mittenti sconosciuti; non rispondere, inoltre, a messaggi intimidatori, minacciosi oppure in cui si richiede denaro o informazioni in quanto potrebbero diffondere codice malevolo (e-mail di *spam* e *phishing*). Tali e-mail devono essere prontamente segnalate alle strutture competenti di Cyber Security Solutions & Operations di FST.
- Non diffondere e utilizzare il proprio indirizzo di posta aziendale per l’iscrizione a siti *web*, a *social network* o per la sottoscrizione a *newsletter*, *mailing list* o per la partecipazione a dibattiti, forum, petizioni, salvo comprovate esigenze connesse all’attività lavorativa. La posta elettronica aziendale non deve essere utilizzata per dar corso a catene telematiche di messaggi (anche dette “Catene di Sant’Antonio”).
- Non comunicare a terze parti il proprio indirizzo di posta o gli indirizzi di posta di altri utenti del Gruppo FS Italiane, se non per esigenze connesse alla propria attività lavorativa.
- Non mistificare il mittente, tramite l’alterazione dei dati relativi alla propria identità. Nell’utilizzo delle caselle di struttura, non inviare messaggi che spendano abusivamente il nome dell’azienda.
- Archiviare esclusivamente su ambienti messi a disposizione dall’azienda comunicazioni inviate o ricevute dalle quali si possano desumere impegni e/o indicazioni operative di rilevanza per la continuità operativa della struttura di appartenenza.
- Per la trasmissione della documentazione confidenziale o strettamente confidenziale e per la documentazione contenente dati personali, utilizzare sistemi di crittografia per proteggere le informazioni dal rischio di furto/smarrimento del dispositivo (fare riferimento al DPO/Referente Data Protection di Società e alla competente struttura di Cyber Security Solutions & Operations di FST per le soluzioni tecniche); inviare i messaggi solo ai soggetti interessati, in coerenza con i ruoli e le responsabilità loro attribuiti.
- Limitare quanto più possibile la dimensione degli allegati (anche comprimendo i file più grandi, ricorrendo a formati quali ad esempio, *.zip, *.jpg, etc.) e l’invio di e-mail a un numero elevato di destinatari.
- Nei periodi di assenza dal lavoro, devono essere utilizzate le apposite funzionalità di sistema (c.d. “*out of office*” o “fuori sede”) che consentono di inviare automaticamente messaggi di risposta contenenti eventuali riferimenti di sostituti autorizzati e/o della segreteria di riferimento da contattare per comunicazioni urgenti. In caso di eventuale assenza non programmata (ad es. per malattia), qualora l’utente non possa attivare la procedura sopra descritta, è fatta salva la facoltà per la Società di disporre lecitamente l’attivazione di un analogo accorgimento attraverso l’amministratore di sistema di posta, dandone comunicazione all’utente stesso.
- Non devono essere utilizzate e/o predisposte (anche se con aggregati transitori) mailing list o liste di distribuzione al fine di inviare messaggi, a meno che tale attività non rientri nello svolgimento di una mansione lavorativa.

- Non devono essere inoltrate verso caselle di posta personali e/o private, né in modo automatico né manuale, i messaggi ricevuti sulla casella di posta aziendale.
- La casella di posta elettronica aziendale deve essere mantenuta in ordine, anche cancellando documenti superflui e, soprattutto, allegati ingombranti non più utili ai fini lavorativi.
- Nell'utilizzo dei sistemi di video-conferenza la registrazione è ammessa solo previo consenso di tutti i partecipanti. Il soggetto che detiene la registrazione è tenuto ad informare preventivamente i partecipanti rispetto allo scopo della registrazione e i tempi di conservazione della medesima.
- Non utilizzare applicazioni di *instant messaging* non autorizzate dalle strutture competenti per i sistemi informativi.
- Non utilizzare i servizi per ragioni diverse da quelle attinenti alle proprie attività lavorative. In particolare, la posta elettronica aziendale, la PEC e il protocollo devono essere utilizzati per scopi lavorativi. Le informazioni presenti all'interno delle caselle di posta elettronica aziendali assegnate e/o utilizzate dagli utenti devono essere considerate come corrispondenza e documentazione lavorativa e non personale, e trattate secondo il *Modello di Governance "Security"*.

Disposizioni per l'utilizzo della rete aziendale, della consultazione delle risorse online (navigazione) e dei social network

L'utente è responsabile dell'uso del servizio di accesso a internet, dei contenuti che vi ricerca, dei siti che contatta, delle informazioni che vi immette e delle modalità con cui opera, a prescindere dalle misure poste in essere per limitare l'accesso a risorse *web*. Al fine di garantire la riservatezza, l'integrità e la disponibilità dei servizi di navigazione sono operativi strumenti di rilevamento automatico dei dati, anonimizzati e aggregati, relativi al traffico. La connessione ad Internet è messa a disposizione degli utenti finali da parte della Società per lo svolgimento dell'attività lavorativa.

Nell'uso della rete aziendale, oltre a quanto riportato nei paragrafi precedenti, è necessario che il personale si attenga alle seguenti disposizioni.

- Non modificare, diffondere, duplicare, detenere, danneggiare o distruggere informazioni, dati, sistemi informativi e risorse informatiche della rete.
- Non diffondere, installare, elaborare, conservare, trasferire apparecchiature o altro materiale che consenta di intercettare, accedere, modificare, danneggiare, distruggere, impedire o interrompere le comunicazioni informatiche o telematiche.
- Non connettere alla rete dati aziendale dispositivi che non siano autorizzati e controllati dal soggetto tecnico per i sistemi informativi (ad es. personal computer, modem, switch, hub, wireless access point, hard disk di rete, telecamere etc.).
- Non diffondere apparecchiature, dispositivi, programmi informatici virus o *malware* diretti a danneggiare o interrompere un sistema informatico o telematico o sfruttare vulnerabilità derivanti da difetti di configurazione o da difetti intrinseci ai programmi e/o ai sistemi.

- Non porre in essere attività intrusive o di sondaggio di qualunque tipo e verso qualunque sistema interno o esterno o effettuare attività volte ad aggirare o compromettere i meccanismi di protezione dei sistemi informatici.
- Non effettuare l'accesso alla rete aziendale da remoto tramite VPN utilizzando credenziali diverse dalle proprie, ovvero attivare accessi remoti contemporanei da diversi dispositivi con le stesse credenziali di accesso.

Rispetto alla navigazione e all'utilizzo dei *social network*, oltre a quanto riportato nei paragrafi precedenti, è necessario che il personale si attenga alle seguenti disposizioni.

- Non pubblicare informazioni aziendali senza disporre di adeguate autorizzazioni.
- Non effettuare operazioni di acquisto e *trading on line* per uso personale.
- Non scaricare, utilizzare (e diffondere) materiale protetto dal diritto d'autore.
- Non accedere a materiale pornografico, osceno o più in generale a qualsiasi materiale avente contenuto scurrile, violento o, in qualsiasi modo, lesivo di persone, razze, sesso e religione; siti che promuovono attività illecite; siti relativi a giochi e di *gaming on line* (scommesse); siti che realizzano scambi di video, audio, testo in modalità *peer-to-peer*, *chat*, *newsgroup*, dibattiti o forum non attinenti alla propria attività lavorativa o comunque non sufficientemente affidabili; servizi di streaming audio e video, se non inerenti all'attività lavorativa.
- È opportuno limitare il più possibile la consultazione di account di posta elettronica personali da postazioni aziendali.
- L'accesso e l'utilizzo dei social network è consentito solo in relazione alle attività lavorative e secondo le linee guida contenute nella *Social Media Policy* del Gruppo FS.
- La connessione ad Internet non deve essere utilizzata per tentare l'accesso a siti o risorse protetti con l'uso di tecniche di attacco di qualsiasi genere, download e utilizzo di *crack*, *patch*, *script* o applicativi atti ad aggirare o inibire, in qualsiasi modo, protezioni hardware e software, ovvero ad ottenere privilegi d'accesso a qualsiasi risorsa di rete non regolarmente attribuiti.
- Gli utenti non devono tentare di disabilitare i sistemi posti in essere dalla Società per bloccare l'accesso ad alcuni siti.
- Gli utenti non devono modificare o mascherare le impostazioni di rete assegnate (ad esempio, *IP address*) o aggirare o disabilitare i dispositivi preposti alla gestione della sicurezza e delle comunicazioni in rete (ad esempio, *firewall*, *proxy*, *router*, etc.).

Disposizioni per l'utilizzo delle applicazioni aziendali e dei servizi di archiviazione e collaboration

La protezione delle applicazioni aziendali, ivi inclusi i servizi di archiviazione e collaboration, deve essere effettuata a diversi livelli per prevenire il verificarsi di eventi che ne possono bloccare o degradare le prestazioni o minare l'integrità e la confidenzialità delle informazioni aziendali e personali che vi risiedono. A tal fine sono operativi strumenti di rilevamento automatico della sicurezza di applicazioni e

servizi.

Nell'uso delle applicazioni software, oltre a quanto riportato nei paragrafi precedenti, è necessario che il personale si attenga alle seguenti disposizioni.

- Non effettuare accessi abusivi di qualsiasi natura ad applicazioni/servizi per i quali non si è stati abilitati.
- Non modificare, eliminare, diffondere e utilizzare informazioni tratte da tali applicazioni/servizi per finalità diverse da quelle strettamente connesse alle mansioni svolte o alla posizione gerarchica ricoperta. L'eventuale trattamento di dati personali che non sia ricompreso nelle istruzioni operative attribuite all'incaricato al trattamento dal *Data Manager* può considerarsi un potenziale *Personal Data Breach*.¹⁶
- Non realizzare, installare e rendere operative nuove applicazioni (al di fuori del catalogo delle applicazioni e di quelle sviluppate su strumenti di informatica individuale forniti dal Gruppo, ad es. macro su foglio di lavoro, Piattaforme *Low-Code/No-Code*), senza il preventivo consenso delle strutture competenti per i sistemi informativi.
- Accedere ad applicazioni software solo quando effettivamente necessario per l'espletamento delle proprie attività lavorative, evitando di utilizzarle per finalità non strettamente connesse alle proprie mansioni e non trattando dati personali al di fuori delle istruzioni operative previste nel suo atto di designazione ad incaricato al trattamento da parte del *Data Manager* relativo.
- Al termine delle attività, è raccomandato svolgere il *log off* dall'applicazione.
- Segnalare eventuali anomalie di funzionamento ai servizi *Help Desk* e supporto informatico delle Società del Gruppo FS.

Nell'uso dei servizi di archiviazione e collaboration, oltre a quanto riportato nei paragrafi precedenti, è necessario che il personale si attenga alle seguenti disposizioni.

- Per lo scambio e la condivisione dei file che contengono informazioni e dati riguardanti l'attività lavorativa deve essere privilegiato l'impiego degli strumenti aziendali di *collaboration* (ad esempio, *SharePoint*, *OneDrive* e *Teams*) in luogo della posta elettronica.
- File o cartelle di lavoro devono essere condivise tra gli utenti (esclusivamente in ambiente cloud aziendale) in accordo ai principi del “*need to know*” e “*least privilege*”, secondo i quali ad un utente è consentito l'accesso al file o alla cartella solo se necessario e con i privilegi minimi per lo svolgimento delle proprie mansioni.
- I file che non contengono informazioni e dati riguardanti l'attività lavorativa (ad esempio, foto, video, contenuti multimediali in genere, documenti personali, etc.) non devono mai essere archiviati sugli strumenti di archiviazione e *collaboration* e/o in cartelle locali del personal computer sincronizzate con tali strumenti.

¹⁶ L'autorizzazione IT ad effettuare specifiche operazioni (es. download, cancellazione, modifica, etc.) non può essere intesa come una autorizzazione generale per effettuare qualsiasi tipo di operazione sui contenuti degli ambienti di sharing. Ad es. il personale non potrà cancellare o modificare contenuti, se non concordato con gli altri partecipanti all'ambiente di sharing. Il trattamento di dati personali è sempre vincolato allo specifico atto di designazione ad incaricato che ciascuno utente del sistema IT dovrà ricevere dal *Data Manager* del trattamento.

CONTROLLI SULLE RISORSE DIGITALI

Il Gruppo FS si avvale di un processo strutturato di verifiche circa il corretto utilizzo delle risorse digitali aziendali, anche attraverso l'analisi del traffico di rete, il monitoraggio dei log delle attività sulle applicazioni a fronte di eventi o segnalazioni di potenziali rischi per l'azienda e il monitoraggio dei costi (inclusi i volumi di traffico delle utenze aziendali rispetto alle direttrici di chiamata), al fine di garantire la sicurezza delle reti e delle informazioni nonché la tutela del patrimonio aziendale. Il processo di verifiche è volto a identificare tempestivamente casi di comportamenti illeciti (anche ai sensi dell'art. 615-quinquies del Codice penale) o in grado di generare eventi di danno per le Società del Gruppo ovvero casi di abuso e/o di utilizzo non conforme a quanto prescritto dal presente documento.

Le attività di controllo sul corretto utilizzo delle risorse digitali si sostanziano in due macrocategorie:

- **Controlli di linea e di Cyber security:** controlli posti in essere dalle strutture competenti per i sistemi informativi e per la Cyber Security Solutions & Operations di FST volti ad evitare l'alterazione della configurazione originaria delle risorse digitali, nonché a prevenire, rilevare e contrastare gli incidenti informatici anche al fine di evitare eventi di data breach, per come definiti nella normativa Data Protection e nel *Framework Data Protection di Gruppo* o nel *Modello di Governance Security*. A tal fine, le strutture competenti per i sistemi informativi e la **funzione Cyber Security di FS Spa** stabiliscono e formalizzano (all'interno di istruzioni operative di struttura) il set di controlli volti a garantire la protezione del patrimonio informativo aziendale; identificano, inoltre, gli strumenti hardware e software utilizzati per le attività di controllo.
- **Controlli interni:** controlli posti in essere dalle funzioni societarie competenti nell'ambito del Sistema di Controllo Interno del Gruppo circa il corretto utilizzo delle risorse digitali **(i) per la realizzazione degli interventi integrati di audit**, pianificati e spot, così come definiti nel vigente Modello di Governance "Internal Audit", **(ii) per la gestione del processo delle segnalazioni**, (c.d. *whistleblowing*) finalizzate al contrasto di qualunque comportamento illecito o irregolarità o condotta posta in essere in violazione del Modello 231 e delle procedure che ne costituiscono attuazione e/o della Policy Anti-Corruption, del Modello di Gestione Anti-Corruption, del Codice Etico, di leggi o regolamenti o normative interne o di provvedimenti delle autorità in ogni caso idonee ad arrecare danno o pregiudizio, anche solo d'immagine o reputazionale, al Gruppo FS **(iii) per gli accertamenti posti in essere dalle competenti funzioni aziendali** nelle situazioni rilevanti che richiedano specifiche indagini interne.

Le Società del Gruppo effettuano i suddetti controlli applicando i principi di gradualità e di minimizzazione del trattamento dei dati personali. A tal fine, riscontrata la necessità di controllo e prima di intervenire con controlli puntuali in caso di anomalie riscontrate, le Società del Gruppo effettuano verifiche basandosi su dati aggregati per funzione/struttura organizzativa e anonimizzati.

Qualora da questa prima fase dovesse emergere un'anomalia (abuso o utilizzo non conforme delle risorse digitali), il controllo anonimo può concludersi con un avviso generalizzato ovvero circoscritto alla struttura organizzativa ove è stata rilevata l'anomalia, con l'invito ad attenersi scrupolosamente a quanto previsto nel presente documento. A questa modalità sono assoggettati anche i soggetti terzi che vengono coinvolti nella prima fase di controllo aggregato all'interno della funzione aziendale ove espletano la loro prestazione a supporto delle Società del Gruppo.

Qualora dopo questa prima fase di analisi dovessero persistere le anomalie ovvero dovessero accertarsi

dei comportamenti illeciti/ idonei a generare eventi di danno per il patrimonio aziendale, si procederà ad una seconda fase di controlli circoscritta alle risorse digitali assegnate/accedute al/dal singolo utente, anche accedendo agli strumenti di comunicazione e tramite analisi dei log prodotti dalle risorse digitali secondo le procedure societarie di gestione dei potenziali *Personal Data Breach* o *Near miss*.

Qualora, nel periodo di vigenza del presente documento, dovessero rilevarsi aggiornamenti/modifiche dei sistemi e/o delle infrastrutture tecnologiche utilizzate per le attività di verifica, tali da rendere il trattamento dei dati personali a rischio elevato per i diritti e le libertà delle persone fisiche, il Responsabile della struttura societaria competente avvierà, anche con il supporto del DPO/Referente *Data Protection* della Società, un *Data Protection Impact Assessment* (DPIA) secondo le modalità previste dal *Framework di Data Protection* e, in particolare, dalle *Linee di indirizzo per l'identificazione dei trattamenti a potenziale rischio elevato e Data Protection Impact Assessment*.

Ciclo dei controlli

Applicazione dei principi di gradualità e minimizzazione nelle attività di cyber security e nei controlli di linea

Le strutture competenti per i sistemi informativi e per la **Cyber Security di FS Spa/ Cyber Security Solutions & Operations di FST** si riservano la facoltà di applicare controlli preventivi/di linea, quali:

- installare sulle risorse digitali aziendali specifici programmi ed altre misure tecniche che impediscano l'installazione e la diffusione di software potenzialmente dannosi per la sicurezza del patrimonio informativo e dei sistemi informatici aziendali, la cui rimozione da parte dell'utente è vietata;
- rimuovere tempestivamente e senza preavviso dai dispositivi aziendali eventuali, *software* (o app) configurazioni, file potenzialmente dannosi per la sicurezza dei dispositivi, dei dati trattati e della rete aziendale. Più in generale, di applicare configurazioni di sicurezza e/o restrizioni di utilizzo ai dispositivi mobili attraverso piattaforme di gestione centralizzata in uso presso le strutture competenti per i sistemi informativi;
- rimuovere dalle risorse digitali aziendali, inclusa la posta elettronica, in qualunque momento, anche senza preavviso, ogni file, applicazione, *app* pericolosa per la sicurezza del patrimonio informativo aziendale, che violi le regole previste all'interno della presente disposizione o che, ad ogni modo, alteri la configurazione originaria delle dotazioni;
- isolare tempestivamente dotazioni informatiche o altre apparecchiature elettroniche dalla rete aziendale nel caso in cui fosse rilevata una minaccia per la sicurezza della rete aziendale.

Inoltre, al fine di prevenire, rilevare e contrastare gli incidenti informatici, la struttura di Cyber Security Solutions & Operations di FST effettua controlli nel continuo su base aggregata e/o anonima. In considerazione della velocità con cui può svilupparsi un attacco informatico, è necessario che eventuali *alert* possano essere analizzati in *real time*. Per tale motivo, le strutture per la Cyber Security Solutions & Operations di FST nel caso dovessero emergere elementi idonei a rilevare comportamenti illeciti o atti a generare eventi di danno per il patrimonio aziendale o *Personal Data Breach*, procedono alla verifica delle posizioni soggettive anche al fine di accertare che l'identità digitale dell'utenza da cui proviene l'anomalia/illecito non sia stata utilizzata abusivamente.

I controlli puntuali sulle posizioni soggettive sono sempre autorizzati dai Responsabili delle strutture competenti per i sistemi informativi e per la Cyber Security Solutions & Operations di FST, che, nei casi in cui si verifica un potenziale rischio di sicurezza, tengono traccia delle attività effettuate e degli esiti delle medesime in un registro delle attività di controllo.

Applicazione dei principi di gradualità e minimizzazione nelle attività di controllo interno

Nell'ambito degli accertamenti e delle analisi svolte per gli interventi di audit integrati, le competenti funzioni societarie hanno accesso a tutte le informazioni, ai dati, sia documentali sia informatici, agli archivi e ai beni delle Società del Gruppo FS, come indicato nel vigente Modello di Governance "Internal Audit". Per l'espletamento di tali attività le competenti funzioni societarie si avvalgono quindi anche di verifiche sulle risorse digitali e procedono svolgendo accertamenti che, compatibilmente con l'oggetto dell'audit effettuato, non comportano in prima analisi un esame delle singole posizioni soggettive delle utenze, che diventano oggetto di trattamento solo in una fase successiva qualora dalla verifica aggregata emergano esigenze di ulteriori approfondimenti.

Nell'ambito del processo di gestione delle segnalazioni che ciascuna Società del Gruppo adotta al fine di contrastare qualunque comportamento illecito, irregolarità o condotta posta in essere in violazione del Modello 231 e delle procedure che ne costituiscono attuazione e/o della Policy Anti-Corruption, del Modello di Gestione Anti-Corruption, del Codice Etico, di leggi o regolamenti o normative interne o di provvedimenti delle autorità, e/o in ogni caso idonee ad arrecare danno o pregiudizio, anche solo d'immagine o reputazionale al Gruppo FS, tali controlli si svolgono nel pieno rispetto delle garanzie previste dalle procedure societarie vigenti a tutela del segnalante, nei cui confronti non dovrà essere effettuata alcuna verifica e dovrà essere pienamente garantita la riservatezza dell'identità e dei fatti oggetto di segnalazione.

Analoga facoltà di avvalersi di verifiche sull'utilizzo delle risorse digitali è riservata alle competenti funzioni aziendali, qualora l'oggetto di indagine necessiti di tali approfondimenti ai fini dell'accertamento delle responsabilità soggettive.

Le verifiche sulle risorse digitali sono effettuate dalla funzione aziendale competente in base alla tipologia di richiesta e/o alle risorse digitali oggetto di controllo. La richiesta di verifica dovrà essere circostanziata rispetto alle risorse digitali da esaminare (precisa indicazione dell'arco temporale e del servizio/strumento digitale oggetto di verifica), priva di riferimenti a persone fisiche identificate o identificabili con eccezione dei soli dati personali relativi all'utenza oggetto di verifica (a titolo esemplificativo CID, indirizzo di posta elettronica, nominativi di assegnatari di caselle di struttura) e non dovrà contenere alcuna indicazione rispetto alla situazione oggetto di segnalazione o di indagine.

Le funzioni aziendali incaricate dei controlli provvederanno ad effettuare le verifiche richieste per il tramite delle persone autorizzate al trattamento.

Al termine delle attività di verifica il Responsabile della struttura societaria incaricata dei controlli comunica l'esito al soggetto richiedente (struttura organizzativa/ organismo/funzione aziendale competente), che, sulla base delle risultanze emerse, potrà chiedere un ulteriore accertamento, ovvero adottare le conseguenziali determinazioni ai fini dell'audit, della segnalazione o dell'oggetto di indagine.

Qualora dall'esito della verifica circostanziata sulle risorse digitali utilizzate nell'ambito del fatto oggetto

di controllo/indagine da parte delle competenti funzioni aziendali, dovessero emergere profili di responsabilità soggettiva rispetto al fatto contestato, ovvero dovessero emergere comportamenti attestanti un abuso e/o un utilizzo non conforme a quanto prescritto dal presente documento, il soggetto richiedente investirà le competenti funzioni aziendali al fine di valutare l'avvio di un procedimento disciplinare di cui al successivo paragrafo.

Resta inteso che, per salvaguardare i propri diritti in sede giudiziaria e/o amministrativa o dare seguito a richieste dell'autorità giudiziaria, amministrativa e di Pubblica Sicurezza, la Società per il tramite delle competenti strutture si riserva la facoltà di accedere, anche successivamente alla cessazione del rapporto di lavoro, alle informazioni e ai dati presenti all'interno delle dotazioni informatiche di un utente.

Monitoraggio e controllo delle attività degli Amministratori di Sistema

Ai sensi del provvedimento del Garante per la Protezione dei Dati Personali recante “misure e accorgimenti prescritti ai titolari dei trattamenti effettuati con strumenti elettronici relativamente alle attribuzioni delle funzioni di amministratore di sistema” (di seguito “Provvedimento Amministratori di Sistema”) e sue successive integrazioni e modifiche, le strutture competenti per i sistemi informativi e per la Cyber Security Solutions & Operations di FST sono tenuti a registrare gli accessi logici effettuati dalle persone autorizzate con mansioni di Amministratore di Sistema (che saranno designati con opportuno atto documentale e registrati nello specifico elenco AdS previsto dalla normativa).

A tal proposito, le strutture competenti per i sistemi informativi e per la Cyber Security Solutions & Operations di FST, per i rispettivi ambiti, adottano idonei sistemi di registrazione degli accessi logici (*access log*) e operazioni effettuate, ivi inclusi il riferimento temporale del *log* e la descrizione dell'evento che ha generato la registrazione. Tali sistemi garantiscono le caratteristiche di completezza e inalterabilità dei *file log*, e la possibilità di verifica della loro integrità in ragione dello scopo di controllo per cui sono richiesti.

Tali registrazioni saranno conservate per un periodo di tempo congruo e, comunque, non inferiore a 6 mesi e comunque nei tempi previsti dalla Data Retention del trattamento di dati personali corrispondente.

Ai sensi del Provvedimento Amministratori di Sistema, le strutture competenti per i sistemi informativi e la Cyber Security Solutions & Operations di FST mantengono l'elenco aggiornato contenente il nominativo dei soggetti qualificati come “Amministratore di Sistema”.

COMPORTAMENTI DIFFORMI ED INIZIATIVE CONSEGUENTI

Nei casi di accertata responsabilità soggettiva dell'uso non corretto delle risorse digitali assegnate e/o dei comportamenti illeciti, come descritto nei paragrafi precedenti, le Società del Gruppo, attraverso le competenti funzioni societarie, pongono in essere le azioni volte a tutelare gli interessi aziendali lesi da tali comportamenti sulla base di quanto previsto dalla normativa vigente.

Qualora le condotte siano riconducibili al personale dipendente (inclusi i dirigenti) delle Società del Gruppo, in violazione dei doveri di fedeltà e diligenza previsti dal Codice civile, dai CCNL e contratti di lavoro rispettivamente applicati al personale dipendente e dirigente del Gruppo, nonché delle prescrizioni contenute nel Codice Etico, le competenti funzioni societarie avviano le procedure disciplinari sulla base della disciplina normativa e contrattuale applicabile. In relazione alla gravità della condotta, saranno altresì effettuate valutazioni circa l'avvio di azioni legali dinanzi alle competenti Autorità Giudiziarie sulla base dell'interesse aziendale leso.

Qualora le condotte siano riconducibili a soggetti terzi, il Gestore del contratto effettua valutazioni in ordine alla gravità della condotta, avvalendosi anche del supporto delle competenti funzioni aziendali (legale, risorse umane, acquisti), e adotta, sulla base di un criterio di proporzionalità ed in coerenza con le relative disposizioni contrattuali, le determinazioni conseguenti, quali:

- la segnalazione alla Società con cui è intrattenuto il rapporto contrattuale in relazione al comportamento rilevato con l'invito/diffida ad adottare le opportune iniziative;
- la risoluzione del rapporto contrattuale in essere e l'avvio delle azioni legali volte a tutelare il Gruppo nelle competenti sedi giudiziarie, laddove i comportamenti difformi dovessero persistere in assenza di idonee iniziative da parte della Società con cui è intrattenuto il rapporto contrattuale.

ADEMPIMENTI NORMATIVI

Con riferimento agli obblighi di informazione previsti dalla normativa in materia di protezione dei dati personali, le Società del Gruppo provvedono a fornire, all'atto della consegna delle risorse digitali, l'informativa ex art. 13 del GDPR al personale dipendente/dirigente, ai soggetti con cui intrattengono rapporto di lavoro parasubordinato, ai tirocinanti, alle terze parti come individuate al punto 1.3 (come da template disponibile sulla intranet aziendale).

Al personale dipendente/dirigente viene altresì fornita un'informativa sulle modalità d'uso delle risorse digitali e di effettuazione dei controlli ai sensi dell'art. 4 comma 3 L. n. 300/70 e s.m.i..

Firmato

Roberto Tundo

- **Amministratore di Sistema (AdS):** ruolo assegnato a uno o più utenti per la gestione, configurazione e manutenzione dei sistemi e della rete informatica. A differenza del Super User, i permessi dell'AdS possono essere limitati.
- **Antispam:** software che intercetta i messaggi di spam (email) e li blocca automaticamente, destinandoli a una cartella apposita;
- **Antivirus, Firewall, Host Intrusion Prevention System (HIPS):** sistema di protezione dei dispositivi da minacce quali virus, malware, etc.;
- **Apparati integrativi postazioni da lavoro:** periferiche (scanner, stampanti, ecc.) che l'azienda mette a disposizione dei dipendenti, ad integrazione delle postazioni di lavoro;
- **Applicazioni software:** strumenti informatici a supporto dei processi di business e di staff, resi disponibili agli utenti per l'esecuzione delle attività e delle funzioni lavorative assegnate;
- **Caselle personali:** una casella postale per la gestione della corrispondenza di un dipendente/dirigente o di un collaboratore il cui accesso è consentito esclusivamente al titolare della casella.
- **Caselle di ruolo:** una casella postale per la gestione della corrispondenza di un dipendente/dirigente in ragione del ruolo organizzativo ricoperto, per il quale ne è prevista la disponibilità, il cui accesso è consentito esclusivamente al titolare del ruolo nel momento dell'accesso.
- **Caselle di struttura:** una casella postale per la corrispondenza di una struttura organizzativa (ove previsto), a cui hanno accesso le risorse allo scopo autorizzate da parte del responsabile della struttura organizzativa
- **Digital workspace (chat, servizi di audio-video conferenza e social aziendali):** strumenti che consentono lo scambio real time di brevi messaggi e di file, offrendo la possibilità di selezionare il destinatario da una lista di contatti integrata con l'Active Directory aziendale, nonché la possibilità di organizzare riunioni ed effettuare call;
- **Dispositivi OTP:** strumenti, detti anche token, che generano una password (*One Time Password*) usa e getta formata da un codice alfanumerico.
- **Dotazioni informatiche:** Strumenti informatici (PC, tablet, smartphone, ecc.) che l'azienda mette a disposizione dei dipendenti nell'esecuzione delle attività lavorative;
- **End-Point encryption:** Sistema di protezione delle informazioni aziendali, presenti sui dispositivi, da accessi non autorizzati attraverso algoritmi di crittografia;
- **Identità digitale:** insieme delle risorse digitali associate in maniera univoca ad una persona fisica che la identifica, rappresentandone la volontà, durante le sue attività digitali;
- **IP address:** l'Internet Protocol Address o indirizzo IP è un codice numerico usato da tutti i dispositivi (computer, server web, stampanti, modem) per navigare in Internet e per comunicare in una rete locale;
- **Memoria esterna:** qualsiasi periferica removibile che permetta di conservare dati. Esempi includono le chiavette USB, gli Hard Disk esterni, le schede SD.

- **Mobile Application Management, Mobile Device Management:** sistemi che impediscono l'uso improprio dei dispositivi mobile aziendali, imponendo da remoto le misure di sicurezza necessarie quali: l'installazione di antivirus, firewall, HIPS e di soluzioni di cifratura; consentono inoltre di bloccare il dispositivo in caso di furto/smarrimento impedendo l'accesso non autorizzato di terzi alle informazioni aziendali;
- **Posta Elettronica:** è lo strumento utilizzato per la trasmissione di messaggi, informazioni aziendali e di file;
- **Posta Elettronica Certificata (PEC):** è lo strumento che garantisce l'equivalenza giuridica della comunicazione elettronica a quella di una raccomandata con ricevuta di ritorno;
- **Responsabile Gestione Autorizzazioni (RGA):** responsabile della gestione degli accessi al sistema, ivi compresi la concessione e il ritiro dei permessi d'accesso;
- **Servizio di Protocollazione:** è lo strumento che certifica la provenienza e la data di acquisizione di un documento. Deve avvenire secondo precise modalità disciplinate da disposizioni tecniche dedicate;
- **Strumenti di archiviazione e collaboration:** infrastruttura di reti e servizi, basata sulla tecnologia cloud / on premises, che consente l'archiviazione dei documenti e collaborazione a distanza.
- **Super User:** utente con il massimo livello di accesso e privilegi sui sistemi informatici. Ha il controllo completo sul sistema e può eseguire qualsiasi operazione.
- **Rete dati LAN:** La Local Area Network è un insieme di dispositivi collegati insieme in un luogo fisico (edificio pubblico o privato, ufficio, casa) permettendone la comunicazione attraverso un collegamento alla rete Internet o una condivisione di dati.
- **Rete dati WI-FI:** insieme di tecnologie per reti locali senza fili (WLAN) che consente a più dispositivi (per esempio personal computer, smartphone, smart TV, ecc.) di essere connessi tra loro tramite Internet e scambiare dati.
- **Rete dati telefonia mobile cellulare (SIM):** rete che permette la telecomunicazione in tutti i punti di un territorio suddiviso in aree di non grandi dimensioni, chiamate "celle" per la telefonia radiomobile cellulare, ognuna servita da una diversa stazione.
- **VPN (*Virtual Private Network*):** rete privata virtuale che garantisce privacy, anonimato e sicurezza attraverso un canale di comunicazione logicamente riservato (tunnel VPN), creato sopra un'infrastruttura di rete pubblica.

RUOLO	DATA	STRUTTURA ORGANIZZATIVA	DOCUMENTO DI RIFERIMENTO
Struttura Sistemi Informativi	26/03/24	Struttura TECHNOLOGY INNOVATION & DIGITAL a diretto riporto dell'AD per l'ambito di competenza	DOr n.22 TID HR 05/06/23
		FS TECHNOLOGY per l'ambito di competenza	
Struttura Cyber di FS Spa	26/03/24	Struttura CYBER & INFORMATION SECURITY in ambito SECURITY & RISK	DOr n.40 SER HR 29/09/23
Struttura Data Protection di FS Spa	26/03/24	Struttura DATA PROTECTION DEPARTMENT in ambito LEGAL AFFAIRS	DOr n.32 LEG HR 01/08/23

RIFERIMENTI NORMATIVI

- Regolamento UE sulla Protezione dei Dati Personali 2016/679 – nel seguito “GDPR”;
- Codice per la Protezione dei Dati Personali – D.Lgs. n.196/2003 come modificato dal D.Lgs. n.101/2018;
- L. n. 300/1970 “Norme sulla tutela della libertà e dignità dei lavoratori, della libertà sindacale e dell’attività sindacale, nei luoghi di lavoro e norme sul collocamento” e s.m.i.;
- L. n. 547/1993 “Modificazioni ed integrazioni alle norme del Codice penale e del codice di procedura penale in tema di criminalità informatica”;
- L. n.48/2008 “Ratifica ed esecuzione della Convenzione del Consiglio d’Europa sulla criminalità informatica”;
- D.L. n. 144/2005, convertito con L. n. 155/2005, “Misure urgenti per il contrasto del terrorismo internazionale”;
- D.Lgs. n. 259/2003 “Codice delle comunicazioni elettroniche”;
- D.Lgs. n.65/2018 “Attuazione della Direttiva (UE) 2016/1148 del Parlamento Europeo e del Consiglio, del 6 luglio 2016, recante misure per un livello comune elevato di sicurezza delle reti e dei sistemi informativi nell’Unione”;
- Linee Guida del Garante per la protezione dei dati personali per la posta elettronica e internet, pubblicato nella Gazzetta Ufficiale n.58 del 10 marzo 2007;
- Provvedimento del Garante per la protezione dei dati personali, del 27 novembre 2008, “Misure e accorgimenti prescritti ai titolari dei trattamenti effettuati con strumenti elettronici relativamente alle attribuzioni delle funzioni di amministratore di sistema”;
- Codice Etico del Gruppo FS;
- Modello Organizzativo e di Gestione di Ferrovie dello Stato Italiane SpA e delle Società del Gruppo ex D.Lgs. 231/2001;
- Policy Anti-Corruption del Gruppo FS Italiane;
- Modello di Governance Anti-Corruption;
- Modello di Gestione per la Protezione dei Dati Personali;
- Modello di Governance Security.

ACCOUNTABILITY: chiara definizione di ruoli e responsabilità dei soggetti che, nell'ambito delle funzioni ricoperte e nel conseguimento dei correlati obiettivi, partecipano attivamente e, per i profili di competenza, assumono le relative responsabilità in relazione alle diverse fasi del processo e di individuazione, mitigazione e monitoraggio dei relativi rischi identificati.

CONTRIBUTO ALLA IDENTIFICAZIONE E MITIGAZIONE DEI RISCHI: consentire che i principali rischi siano identificati, valutati, mitigati e monitorati, al fine di supportare il management nell'assunzione di decisioni consapevoli ed allo scopo di minimizzare gli impatti degli stessi sul raggiungimento degli obiettivi cui sono collegati e sulla reputazione della Società.

SEGREGAZIONE DELLE RESPONSABILITÀ: rispetto del principio della segregazione delle responsabilità in base al quale deve essere garantito che il responsabile dell'attività operativa sia sempre un soggetto distinto da quello che esegue le attività di controllo e di monitoraggio della stessa.

IMPARZIALITÀ E ASSENZA DI CONFLITTI DI INTERESSE: i dipendenti delle Società del Gruppo coinvolti nel processo devono operare con professionalità e imparzialità evitando ogni conflitto di interesse, ossia una situazione in cui la detenzione, anche indiretta o per conto di terzi, di un interesse secondario interferisce o potrebbe interferire con la capacità di agire nell'interesse primario della Società. Il dipendente che si trovi in una siffatta situazione è tenuto a darne tempestiva comunicazione al proprio superiore per le determinazioni del caso e ad astenersi, nelle more, dall'assunzione di decisioni o dallo svolgimento di attività in conflitto con gli interessi del Gruppo.

SISTEMA DI DELEGHE E POTERI: definizione formale di deleghe e poteri di firma, in coerenza con le posizioni organizzative e le missioni/responsabilità assegnate, da esercitarsi secondo le modalità ed entro i limiti di valore predefiniti.

RISERVATEZZA: fermi restando la trasparenza delle attività poste in essere e gli obblighi di informazione imposti dalle disposizioni vigenti, è obbligo delle risorse che operano nelle diverse fasi del processo garantire la riservatezza richiesta dalle circostanze per ciascuna notizia/informazione appresa in ragione della propria funzione lavorativa, anche in relazione alla particolare sensibilità di alcuni dati trattati. Le metodologie e gli strumenti per la protezione della riservatezza delle informazioni sono orientati a garantire l'integrazione con i processi aziendali nella ricerca della massima efficienza ed evitando la ridondanza dei controlli.

CREAZIONE DI VALORE: le attività previste all'interno del documento concorrono alla creazione di valore per il Gruppo, i clienti, il personale e gli altri stakeholder, favorendo il miglioramento continuo dei processi, dei modelli di governance e degli strumenti di organizzazione, gestione e controllo attraverso l'aggiornamento professionale delle risorse coinvolte nel processo, implementazione e continuo miglioramento dei sistemi di monitoraggio e reporting.

TRACCIABILITÀ E ARCHIVIAZIONE: i soggetti coinvolti nelle diverse fasi del processo devono garantire, ciascuno per la parte di propria competenza, la tracciabilità delle attività svolte e l'archiviazione, ove possibile anche tramite l'utilizzo di adeguati supporti informatici, della relativa documentazione, assicurando, nel tempo, l'individuazione e la ricostruibilità ex post delle fonti e degli elementi informativi che supportano le attività.



VERSIONE/DATA	DOCUMENTO	MOTIVO DELLA REVISIONE
1.0 del 26/03/2024	GR_PY_ Utilizzo corretto e sicuro delle Risorse Digitali_n.65_v.01	Prima emissione

La presente policy aggiorna e sostituisce la DdG n.303 del 3 maggio 2022 "Policy sull'utilizzo corretto e sicuro delle Risorse Digitali".